Risk Assessment Report (RAR)

Meridian Health Partners

MyMeridian Patient Portal

24 September 2026

Record of Changes:

Version	Date	Sections Modified	Description of Changes
1.0	24 Sep 26	All	Initial release of the Risk Assessment Report for the MyMeridian Patient Portal.

System Description

System Name: MyMeridian Patient Portal

Organization: Meridian Health Partners — a nonprofit regional healthcare system operating 6 hospitals and 40+ outpatient clinics across Ohio, Indiana, and Kentucky.

Location: Corporate headquarters: 500 Meridian Way, Columbus, OH 43215. Primary data center: Meridian's on-premise facility, Columbus, OH. Portal and telehealth infrastructure hosted in AWS us-east-2 (Ohio) region.

Points of Contact:

System Owner: Director of Digital Patient Experience, Meridian Health Partners

Information System Security Officer (ISSO): Senior Security Analyst, Meridian IT Security

Privacy Officer: Chief Privacy Officer, Meridian Health Partners (HIPAA Privacy Rule compliance lead)

System Boundary: The MyMeridian Patient Portal comprises the custom-built, patient-facing web and mobile application, its integration with the telehealth platform (third-party, cloud-hosted on AWS), the billing/payment module, and the interface layer connecting the portal to the organization's Epic EHR. The boundary excludes the core clinical EHR system itself and the on-premise biomedical device network, which are assessed separately.

Mission: The portal provides patients with secure access to their health records, appointment scheduling, secure messaging with providers, telehealth visits, and online bill payment, supporting Meridian's mission of accessible, patient-centered care across its service region.

System Security Categorization: FIPS 199 categorization:

- **Confidentiality:** High (large volume of ePHI; unauthorized disclosure would have severe impact)
- **Integrity:** Moderate (incorrect patient data could affect care decisions, but downstream clinical verification exists via EHR)
- **Availability:** Moderate (portal outage inconveniences patients but does not halt direct clinical care, which continues through the EHR and in-person channels)
- **Overall System Categorization:** High, per the FIPS 199 high-water-mark methodology.

Type of Data Processed / Classification: Electronic protected health information (ePHI) for approximately 2.1 million unique patients; cardholder data associated with the patient billing feature (in scope for PCI-DSS); limited employee-facing data for customer support staff accessing the admin console. Data is classified as Confidential / Sensitive under Meridian's internal data classification policy.

Scope

This is a Tier 3 risk assessment, focused on the MyMeridian Patient Portal's use of resources and controls to mitigate vulnerabilities exploitable by identified threat sources, consistent with the control selection made during the Risk Management Framework (RMF) process for this system.

This assessment is not comprehensive of every possible threat and vulnerability to the portal. It covers risks related to the design, configuration, and operation of the portal and its direct integrations (telehealth platform, payment module, EHR interface) as of the assessment date. It does not extend to the core Epic EHR system, the biomedical device network, or Meridian's corporate IT environment, which fall under separate assessments.

Assumptions/Constraints: This assessment is based solely on the provided system architecture diagram for the MyMeridian Patient Portal. It does not include interviews with staff, review of policy or configuration documents, penetration testing, source code review, or independent technical control validation. The assessment reflects the system's state as of the assessment date and assumes the portal operates as depicted in the diagram. Findings are limited to the information made available to the assessment team at the time of review.

Because the assessed organization is fictional, the following constraints apply. Threat events are illustrative and constructed to plausibly align with each identified vulnerability. They are not derived from an organization-specific threat intelligence feed, incident history, or sector-specific advisory data, as would be standard practice in an operational assessment. Technical findings (R-0001 through R-0013) are drawn from the architecture diagram. Operational and Management findings (R-0014 through R-0025) reflect assumed organizational conditions constructed for this exercise in place of document review and personnel interviews. Existing controls listed as mitigating factors are likewise assumed for the purposes of this exercise.

Purpose

This initial risk assessment was conducted to document areas where the selection and implementation of security controls for the MyMeridian Patient Portal may leave residual risk, particularly given the portal's rapid scale-up following the 2022 telehealth launch. This assessment provides system owners, security control assessors, and authorizing officials an upfront risk profile to support authorization and prioritization decisions.

Risk Assessment Approach

This risk assessment was conducted using the guidelines outlined in NIST SP 800-30, Guide for Conducting Risk Assessments. A qualitative approach was used for this assessment. Risk is determined based on an identified threat event, the likelihood of that threat event occurring, known system vulnerabilities and predisposing characteristics, existing mitigating factors, and the resulting consequence or impact to the mission.

The following table provides sample threat sources used to identify relevant threats to the portal. Based on the evaluated threats, the resulting risks are documented in Table 7: Risk Assessment Results, along with identified mitigating factors.

Table 1: Sample Threat Sources (see NIST SP 800-30 for complete list)

TYPE OF THREAT SOURCE	DESCRIPTION
ADVERSARIAL - Individual (outsider, insider, trusted, privileged) - Group (ad-hoc or established) - Organization (competitor, supplier, partner, customer) - Nation state	Individuals, groups, organizations, or states that seek to exploit the organization's dependence on cyber resources (i.e., information in electronic form, information and communications, and the communications and information-handling capabilities provided by those technologies.
NON-ADVERSARIAL - Standard user - Privileged user/Administrator	Erroneous actions taken by individuals in the course of executing everyday responsibilities.
STRUCTURAL - IT Equipment (storage, processing, comm., display, sensor, controller) - Environmental conditions o Temperature/humidity controls o Power supply - Software o Operating system o Networking o General-purpose application o Mission-specific application	Failures of equipment, environmental controls, or software due to aging, resource depletion, or other circumstances which exceed expected operating parameters.

TYPE OF THREAT SOURCE	DESCRIPTION
ENVIRONMENTAL - Natural or man-made (fire, flood, earthquake, etc.) - Unusual natural event (e.g., sunspots) - Infrastructure failure/outage (electrical, telecomm.)	Natural disasters and failures of critical infrastructures on which the organization depends, but is outside the control of the organization. Can be characterized in terms of severity and duration.

Table 2: Assessment Scale – Likelihood of Threat Event Initiation (Adversarial)

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	Adversary is **almost certain** to initiate the threat event.
High	80-95	8	Adversary is **highly likely** to initiate the threat event.
Moderate	21-79	5	Adversary is **somewhat likely** to initiate the threat event.
Low	5-20	2	Adversary is **unlikely** to initiate the threat event.
Very Low	0-4	0	Adversary is **highly unlikely** to initiate the threat event

Table 3: Assessment Scale – Likelihood of Threat Event Occurrence (Non-adversarial)

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	Error, accident, or act of nature is **almost certain** to occur; or occurs **more than 100 times per year**.
High	80-95	8	Error, accident, or act of nature is **highly likely** to occur; or occurs **between 10-100 times per year**.
Moderate	21-79	5	Error, accident, or act of nature is **somewhat likely** to occur; or occurs **between 1-10 times per year**.
Low	5-20	2	Error, accident, or act of nature is **unlikely** to occur; or occurs **less than once a year,** but **more than once every 10 years**.
Very Low	0-4	0	Error, accident, or act of nature is **highly unlikely** to occur; or occurs **less than once every 10 years**.

Table 4: Assessment Scale – Impact of Threat Events

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	The threat event could be expected to have **multiple severe or catastrophic** adverse effects on organizational operations, organizational assets, individuals, other organizations, or the Nation.

Qualitative Values	Semi-Quantitative Values		Description
High	80-95	8	The threat event could be expected to have a **severe or catastrophic** adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation. A severe or catastrophic adverse effect means that, for example, the threat event might: (i) cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions; (ii) result in major damage to organizational assets; (iii) result in major financial loss; or (iv) result in severe or catastrophic harm to individuals involving loss of life or serious life threatening injuries.
Moderate	21-79	5	The threat event could be expected to have a **serious** adverse effect on organizational operations, organizational assets, individuals other organizations, or the Nation. A serious adverse effect means that, for example, the threat event might: (i) cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced; (ii) result in significant damage to organizational assets; (iii) result in significant financial loss; or (iv) result in significant harm to individuals that does not involve loss of life or serious life threatening injuries.
Low	5-20	2	The threat event could be expected to have a **limited** adverse effect on organizational operations, organizational assets, individuals other organizations, or the Nation. A limited adverse effect means that, for example, the threat event might: (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced; (ii) result in minor damage to organizational assets; (iii) result in minor financial loss; or (iv) result in minor harm to individuals.
Very Low	0-4	0	The threat event could be expected to have a **negligible** adverse effect on organizational operations, organizational assets, individuals other organizations, or the Nation.

Table 5: Assessment Scale – Level of Risk

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	Threat event could be expected to have **multiple severe or catastrophic** adverse effects on organizational operations, organizational assets, individuals, other organizations, or the Nation.
High	80-95	8	Threat event could be expected to have a **severe or catastrophic** adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.

Qualitative Values	Semi-Quantitative Values		Description
Moderate	21-79	5	Threat event could be expected to have a **serious** adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.
Low	5-20	2	Threat event could be expected to have a **limited** adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.
Very Low	0-4	0	Threat event could be expected to have a **negligible** adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.

Table 6: Assessment Scale – Level of Risk (Combination of Likelihood and Impact)

Likelihood (That Occurrence Results in Adverse Impact)	Level of Impact				
	Very Low	**Low**	**Moderate**	**High**	**Very High**
Very High	Very Low	Low	Moderate	High	Very High
High	Very Low	Low	Moderate	High	Very High
Moderate	Very Low	Low	Moderate	Moderate	High
Low	Very Low	Low	Low	Low	Moderate
Very Low	Very Low	Very Low	Very Low	Low	Low

Table 7: Risk Assessment Results

Risk ID	Threat Source Category	Threat Event	Vulnerabilities / Predisposing Characteristics	Mitigating Factors	Likelihood (Table 2 or 3)	Impact (Table 4)	Risk (Table 5)
R-0001	Adversarial	An attacker uses a non-secure port to attack or infiltrate the network.	ALB accepts inbound HTTP (port 80), no forced HTTPS redirect	None Identified.	High	Moderate	Moderate
R-0002	Adversarial	An attacker performs a brute-force attack on the public-facing RDS.	RDS is publicly accessible with encryption disabled	None Identified.	High	Very High	Very High

Risk ID	Threat Source Category	Threat Event	Vulnerabilities / Predisposing Characteristics	Mitigating Factors	Likelihood (Table 2 or 3)	Impact (Table 4)	Risk (Table 5)
R-0003	Adversarial	An attacker gains access to the S3 bucket and obtains any uploaded record with no issues.	S3 bucket policy grants GetObject to *	None Identified.	Moderate	High	Moderate
R-0004	Non-Adversarial (Accidental)	An engineer accidentally deletes a record while working on the uploaded records, and the record is permanently deleted.	S3 bucket versioning disabled	None Identified.	Low	Low	Low
R-0005	Adversarial	An external malicious actor leverages a botnet to launch a high-volume Layer 7 HTTP flood attack against the public Application Load Balancer (ALB).	No WAF present anywhere in the provided architecture; no filtering at the public ALB	None Identified.	Moderate	Very High	High
R-0006	Adversarial	An attacker exfiltrates data via malicious payloads through the outbound telehealth vendor path.	No WAF present anywhere in the provided architecture; the outbound path to the telehealth vendor	None Identified.	Low	Very High	Moderate

Risk ID	Threat Source Category	Threat Event	Vulnerabilities / Predisposing Characteristics	Mitigating Factors	Likelihood (Table 2 or 3)	Impact (Table 4)	Risk (Table 5)
R-0007	Adversarial	An attacker compromises the telehealth vendor's environment or gains network access to the VPN path and injects malicious traffic toward the EHR-interface Lambda. With no WAF filtering that path, the traffic reaches the interface unimpeded, corrupting data in transit or triggering unauthorized syncs from the portal database.	No WAF present anywhere in the provided architecture; the VPN to the EHR	Telehealth /EHR traffic travels over a Site-to-Site VPN (encrypted, restricted path).	Low	Very High	Moderate
R-0008	Non-Adversarial (Accidental)	An intern with access to the billing service fully deletes all records in both the database and the bucket.	Portal/billing ECS task role granted broad managed policies (S3FullAccess, RDSFullAccess)	None Identified.	Moderate	Very High	High
R-0009	Environmental	An earthquake in Ohio takes out the data center.	Single-AZ RDS deployment with no failover mechanism shown in the architecture	None Identified.	Very Low	Very High	Low

Risk ID	Threat Source Category	Threat Event	Vulnerabilities / Predisposing Characteristics	Mitigating Factors	Likelihood (Table 2 or 3)	Impact (Table 4)	Risk (Table 5)
R-0010	Adversarial	A disgruntled developer intern with access to the AWS console takes and distributes the keys.	Database credentials and the telehealth vendor API key both stored in plaintext as ECS task environment variables, not in a secrets manager	None Identified.	Low	High	Low
R-0011	Adversarial	An attacker compromises the EHR-interface Lambda function and uses its Administrator Access permissions to move laterally across the AWS account, accessing or modifying resources far beyond the EHR sync's intended scope.	EHR-interface Lambda function granted AdministratorAccess	None Identified.	Moderate	Very High	High
R-0012	Adversarial	A known credential-hacking group gains administrator access to the AWS account and stops CloudTrail logging entirely.	CloudTrail logs to a single trail in the same account, with no cross-account or immutable log copy	CloudTrail is enabled and logs account API activity.	Low	High	Low

Risk ID	Threat Source Category	Threat Event	Vulnerabilities / Predisposing Characteristics	Mitigating Factors	Likelihood (Table 2 or 3)	Impact (Table 4)	Risk (Table 5)
R-0013	Adversarial	An attacker compromises the lower-sensitivity portal service and pivots laterally into the PCI-scoped billing workload because both share the same IAM role and subnet.	Billing service (PCI-scoped) shares the same subnet and IAM role as the general-purpose portal service, with no isolation	None Identified.	Moderate	High	Moderate
R-0014	Non-Adversarial (Accidental)	A terminated or role-changed employee retains access to patient records for months beyond the annual review cycle. This unreviewed access is used or misused before the next recertification catches it.	Access recertification is inconsistent and exceeds its stated annual cadence	An annual access recertification process exists, though it is inconsistently executed.	High	Moderate	Moderate

Risk ID	Threat Source Category	Threat Event	Vulnerabilities / Predisposing Characteristics	Mitigating Factors	Likelihood (Table 2 or 3)	Impact (Table 4)	Risk (Table 5)
R-0015	Non-Adversarial (Accidental)	A patient or staff member leaves a session open on a shared or public device longer than intended. Because the timeout is not verified, the session remains active longer than assumed, exposing the account to unauthorized use.	No documented or verified session timeout configuration on the portal	None Identified.	Low	Low	Low
R-0016	Non-Adversarial (Accidental)	Patient-uploaded documents (insurance cards, forms) are retained indefinitely with no defined disposal point. Accumulated, unmanaged patient data increases the volume exposed if any other vulnerability (e.g., the public S3 bucket) is exploited.	No defined retention/disposal policy specific to patient-uploaded documents	None Identified.	Moderate	Moderate	Moderate

Detailed Risk Analysis

Detailed analyses cover findings rated High or Very High (R-0002, R-0005, R-0008, R-0011). All other findings are documented in Table 7.

R-0002: Publicly Accessible, Unencrypted Patient Database

Risk Level	Very High (Likelihood: High, Impact: Very High)
Description	The RDS PostgreSQL instance (meridian-portal-db) is configured as publicly accessible, and its security group allows inbound port 5432 from 0.0.0.0/0. The database endpoint is therefore reachable from the Internet by any attacker, who needs only valid credentials to connect. Those credentials can be obtained through brute-force or credential-guessing attacks, and nothing in the architecture limits or detects repeated attempts. Storage encryption is also disabled, which leaves the underlying storage, automated backups, and snapshots unprotected if they are exposed or accessed outside the database engine.
Business Impact	The database holds ePHI for roughly 2.1 million patients. Unauthorized access would trigger HIPAA/HITECH breach notification at maximum scale, and likely OCR investigation, regulatory penalties, and litigation. It would also seriously damage patient trust in Meridian.

Control Mapping	NIST 800-53: SC-7 (Boundary Protection), SC-28 (Protection of Information at Rest), AC-7 (Unsuccessful Logon Attempts), IA-5 (Authenticator Management). HIPAA: §164.312(a)(1) Access Control, §164.312(a)(2)(iv) Encryption and Decryption.
Recommendation	Set the database to private. Only allow access from the ECS service's security group. Encrypt all data that is stored when it is not in use (this will require creating a copy of the RDS instance through a snapshot and then restoring it). Add monitoring for connections and create alerts if there are any failures with authentications.

R-0005: No WAF Protecting the Public Application Load Balancer

Risk Level	**High (Likelihood: Moderate, Impact: Very High)**
Description	No web application firewall or request-filtering layer exists in front of the internet-facing ALB. High-volume application-layer (Layer 7) traffic, such as a botnet-driven HTTP flood, reaches the portal application unfiltered.
Business Impact	A successful flood would make the portal unavailable. Patients would lose access to records, scheduling, secure messaging, telehealth visits, and bill payment. Clinical care continues through the EHR and in-person channels, but the disruption would hurt patient experience and the telehealth line of business.
Control Mapping	NIST 800-53: SC-5 (Denial-of-Service Protection), SC-7 (Boundary Protection), SI-4 (System Monitoring). HIPAA: §164.306(a)(1) (availability of ePHI), §164.308(a)(7) Contingency Plan.
Recommendation	Attach AWS WAF to the ALB with managed rule sets and rate-based rules. Enable ALB access logging and alert on anomalous traffic patterns.

R-0008: Broad IAM Permissions on the Portal/Billing Task Role

Risk Level	**High (Likelihood: Moderate, Impact: Very High)**
Description	The ECS task role shared by the portal and billing services uses broad AWS managed policies (S3FullAccess, RDSFullAccess) rather than permissions scoped to specific resources and actions. Any user or process operating under this role can modify or delete far more than its function requires.
Business Impact	A single error or misuse can destroy or alter patient and billing data across both the database and the upload bucket. Without versioning or tested backups (see R-0004), recovery may be incomplete. This disrupts both portal operations and the PCI-scoped billing workload.

Control Mapping	NIST 800-53: AC-6 (Least Privilege), AC-2 (Account Management), AC-3 (Access Enforcement), CP-9 (System Backup). HIPAA: §164.308(a)(4) Information Access Management, §164.312(a)(1) Access Control.
Recommendation	Replace the AWS managed policies (S3FullAccess, RDSFullAccess) with custom least-privilege policies. These policies should be specific to the named resource or action(s) needed by the user. Create an additional task role for the billing service. Add MFA Delete and Versioning on the upload bucket. Validate the effective permission settings using IAM Access Analyzer.

R-0011: AdministratorAccess on the EHR-Interface Lambda

Risk Level	**High (Likelihood: Moderate, Impact: Very High)**
Description	The ehr-interface-sync Lambda function runs with the AdministratorAccess policy. Its function is limited to a scheduled sync between the portal database and the EHR, but its permissions cover the entire AWS account. If the function is compromised, the attacker inherits those permissions.
Business Impact	Compromise of one small function would give an attacker unrestricted control of the account. That includes the ability to read or exfiltrate data, alter or destroy resources, and disable security controls such as logging. The blast radius far exceeds the function's purpose.
Control Mapping	NIST 800-53: AC-6 (Least Privilege), AC-6(5) (Privileged Accounts), AC-2 (Account Management), SI-4 (System Monitoring). HIPAA: §164.308(a)(4) Information Access Management, §164.312(a)(1) Access Control.
Recommendation	Substitute the AdministratorAccess with a specifically designed execution role that has been granted the minimum amount of permission (database access, VPN path access and log access) needed for the sync process.